

RAPPORT DE TRAVAUX PRATIQUES : SÉCURITÉ RÉSEAU

TP 4.1 — Mise en place d'un pare-feu pfSense et segmentation du laboratoire

I. Objectif Global

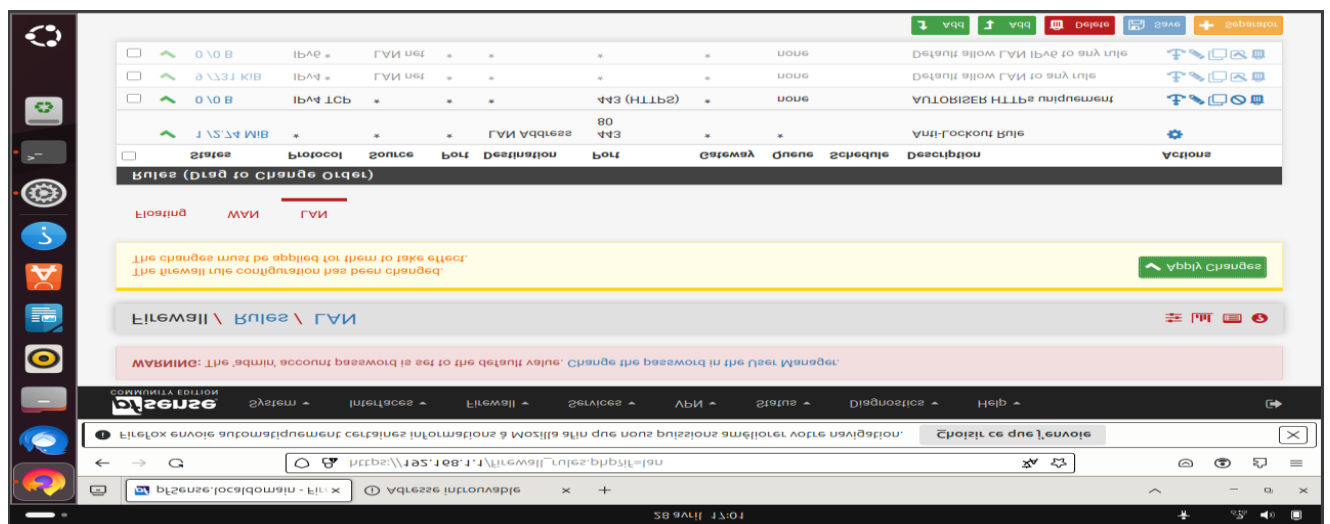
L'objectif est de transformer un réseau local ouvert et vulnérable en une infrastructure segmentée. Nous passons d'une posture d'attaquant à celle d'un **analyste SOC** ou **administrateur sécurité** en utilisant pfSense pour contrôler les flux, limiter la surface d'attaque et détecter les comportements suspects.

II. Déroulement des Étapes (1 à 10)

Étape 1 & 2 : Création et Configuration Réseau (VirtualBox)

Nous avons créé une VM pfSense avec deux interfaces distinctes pour séparer le trafic.

- **Interface 1 (WAN) :** Mode NAT (Simulation d'Internet/Attaquant).
- **Interface 2 (LAN) :** Mode Host-Only (Réseau interne sécurisé).



Paramètres réseau de la VM pfSense montrant les deux cartes réseau

Étape 3 & 4 : Installation et Attribution des Interfaces

Après l'installation de pfSense, nous avons associé les cartes :

- WAN Première carte réseau.
- LAN Deuxième carte réseau.

Étape 5 & 6 : Configuration IP du LAN et des Clients

L'adresse de la passerelle pfSense est fixée à **192.168.1.1**. Nous devons configurer les machines Ubuntu et Windows pour qu'elles utilisent ce réseau.

Commandes sur Ubuntu :

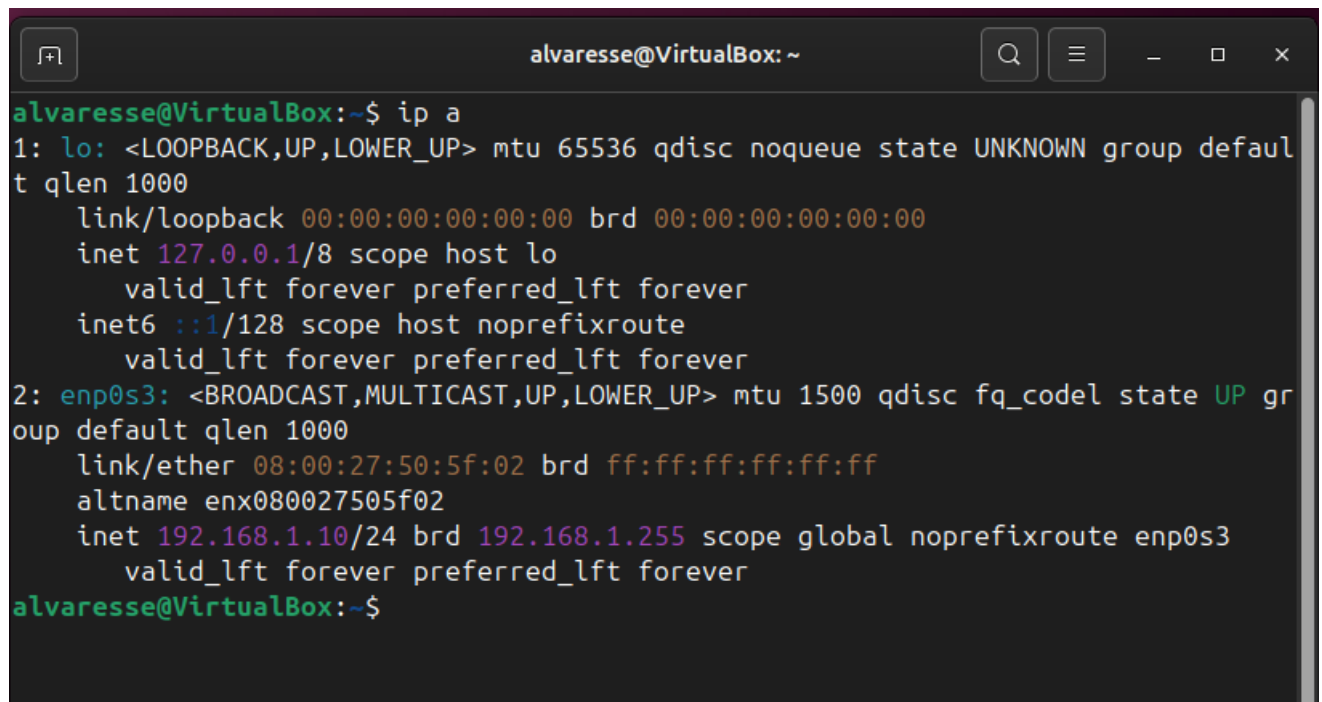
Bash

```
# Attribution de l'adresse IP statique
sudo ip addr add 192.168.1.10/24 dev eth0

# Définition de la passerelle par défaut (pfSense)
sudo ip route add default via 192.168.1.1
```

Configuration sur Windows :

- IP : 192.168.1.20 | Masque : 255.255.255.0 | Passerelle : 192.168.1.1

A screenshot of a terminal window titled 'alvaresse@VirtualBox: ~'. The terminal shows the output of the command 'ip a'. It displays details for the loopback interface 'lo' (127.0.0.1) and the ethernet interface 'enp0s3' (192.168.1.10). The 'enp0s3' interface is shown with its MAC address, broadcast address, and the assigned IP address and netmask. The terminal text is as follows:

```
alvaresse@VirtualBox:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:50:5f:02 brd ff:ff:ff:ff:ff:ff
    altname enx080027505f02
    inet 192.168.1.10/24 brd 192.168.1.255 scope global noprefixroute enp0s3
        valid_lft forever preferred_lft forever
alvaresse@VirtualBox:~$
```

Résultat de la commande 'ip addr' sur Ubuntu montrant l'IP 192.168.1.10

Vérification des adresses

Re

C:\Windows\system32\cmd.exe

Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Users\ALVARESSE>ipconfig

Windows IP Configuration

Ethernet adapter Local Area Connection:

Connection-specific DNS Suffix . :
Link-local IPv6 Address : fe80::f107:64be:b1d6:eefaz11
IPv4 Address. : 192.168.1.20
Subnet Mask : 255.255.255.0
Default Gateway : fe80::1:1%11
192.168.1.1

Tunnel adapter isatap.{BA0BCDB1-3A36-4576-A3C1-7FFF69CA68EA}:

Media State : Media disconnected
Connection-specific DNS Suffix . :

C:\Users\ALVARESSE>_

Étape 7 & 8 : Accès Web et Vérification du Routage

Nous accédons à l'interface de gestion via le navigateur sur Ubuntu : <https://192.168.1.1>

The screenshot shows a Ubuntu desktop environment. The top panel displays the date and time as '28 avril 17:00'. The left sidebar contains icons for the Dash, Home Folder, Applications, and various system utilities. The main window is a Firefox browser displaying the pfSense firewall rules configuration page at https://192.168.1.1/firewall_rules.php?if=lan. The browser's address bar shows the URL and a warning icon. Below the address bar, a message states: 'Firefox envoie automatiquement certaines informations à Mozilla afin que nous puissions améliorer votre navigation.' The main content area shows a table of firewall rules titled 'Rules (Drag to Change Order)'. The table has columns for States, Protocol, Source, Port, Destination, Port, Gateway, Queue, and Schedule. The first rule is highlighted in green and shows a status of '0 / 2.71 MiB'. Below the browser window, a terminal window is open, showing the command 'ping 8.8.8.8' being executed. The output indicates a 100% packet loss.

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule
✓ 0 / 2.71 MiB	*	*	*	LAN Address	443 80	*	*	
✓ 0 / 0 B	IPv4 TCP	*	*	*	80 (HTTP)	*	none	
✓ 5 / 705 KiB	IPv4 *	LAN net	*	*	*	*	none	
✓ 0 / 0 B	IPv6 *	LAN net	*	*	*	*	none	

```
alvaresse@VirtualBox: ~  
alvaresse@VirtualBox:~$ ping 8.8.8.8  
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.  
^C  
--- 8.8.8.8 ping statistics ---  
3 packets transmitted, 0 received, 100% packet loss, time 2065ms  
alvaresse@VirtualBox:~$
```

(Utilisateur : admin / Password : pfsense).

Commande de vérification (Ubuntu) :

Bash

```
# Test de connectivité vers Internet via pfSense
```

ping 8.8.8.8

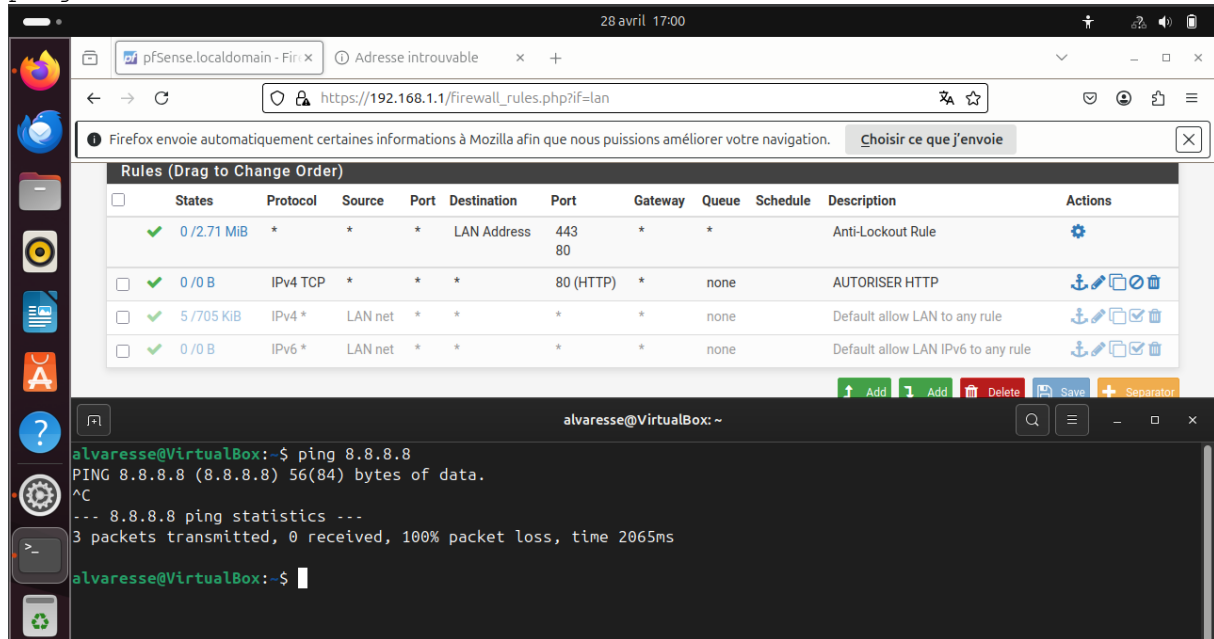
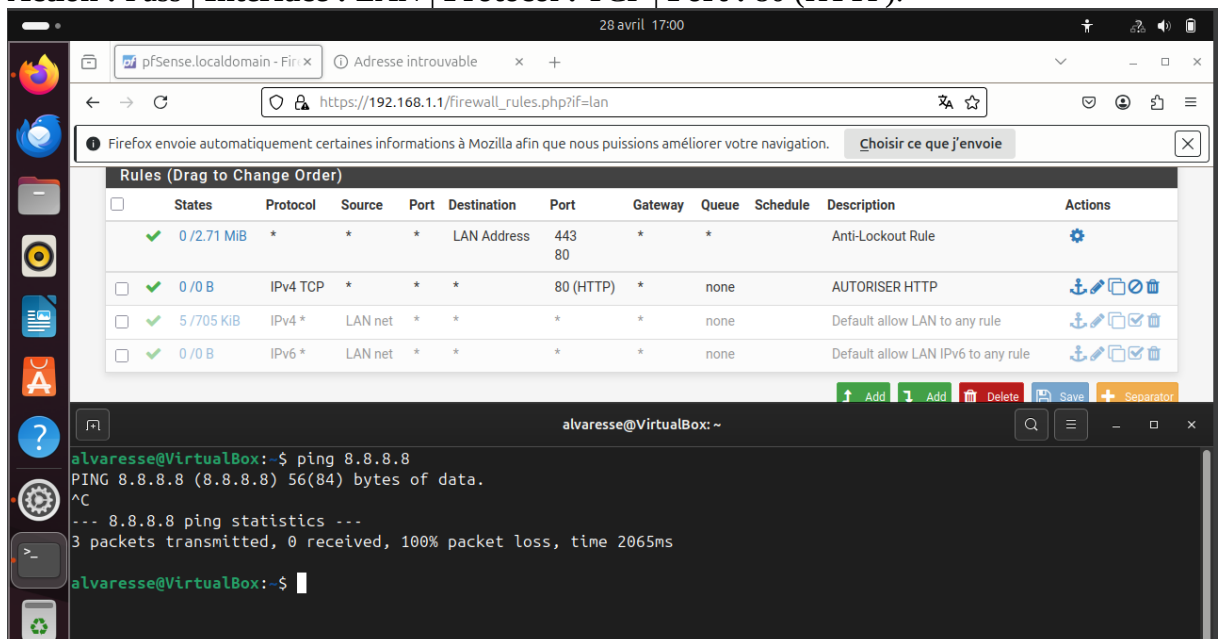


Tableau de bord (Dashboard) de pfSense accessible depuis le navigateur d'Ubuntu

Étape 9 : Mise en place d'une règle de filtrage

Nous avons modifié le comportement par défaut pour ne laisser passer que le flux Web (HTTP).

- **Action : Pass | Interface : LAN | Protocol : TCP | Port : 80 (HTTP).**



Liste des règles dans "Firewall > Rules > LAN" montrant la règle HTTP active

Étape 10 : Tests de fonctionnement et Simulation d'attaque

C'est ici que nous validons la sécurité de l'architecture.

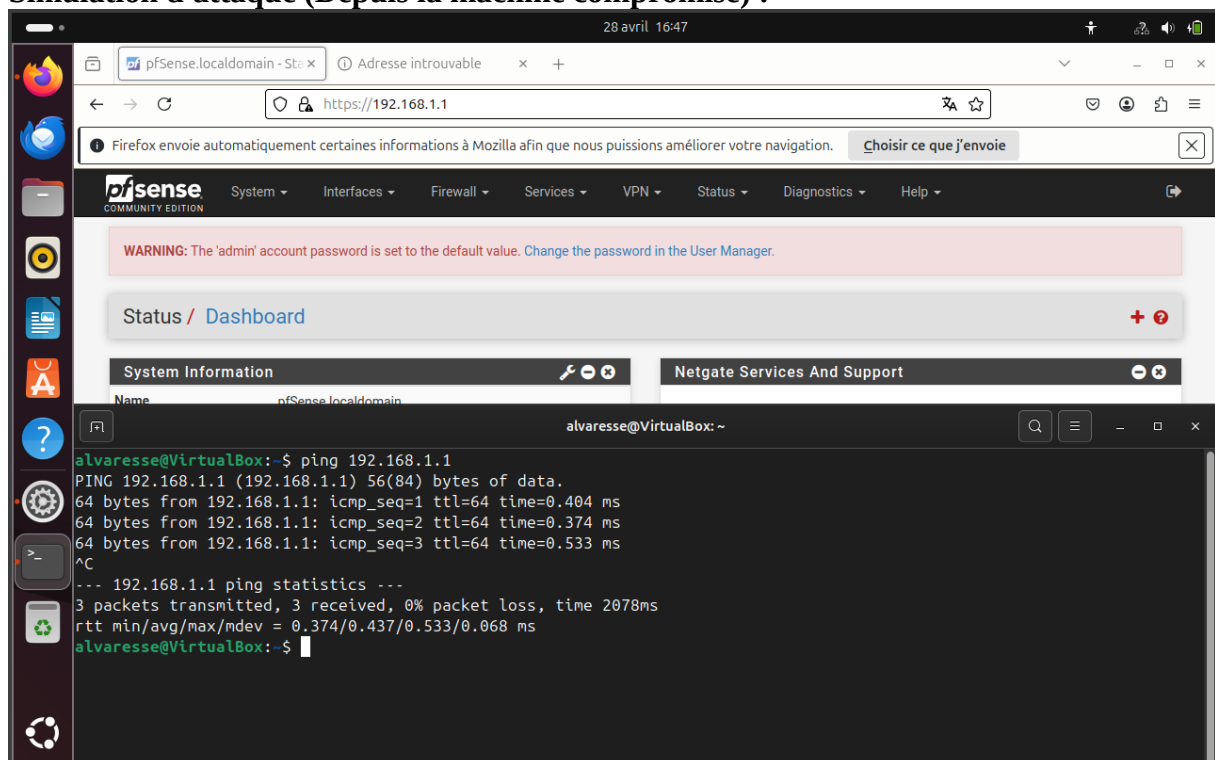
Commandes de test (Ubuntu) :

Bash

```
# Test HTTP (doit fonctionner)
curl http://example.com

# Test de ping (doit échouer car non autorisé)
ping 8.8.8.8
```

Simulation d'attaque (Depuis la machine compromise) :



Bash

```
# Tentative de scan furtif bloquée par le pare-feu
nmap -sS 8.8.8.8
```

Écran scindé montrant le succès du 'curl' et l'échec du 'ping'

III. Interprétation des Résultats

Le pare-feu remplit son rôle de **gardien**. En bloquant les communications non autorisées (comme le ping ou les scans de ports), nous empêchons un attaquant ayant pris le contrôle d'une machine interne de communiquer avec ses serveurs de commande ou de scanner le réseau externe.

IV. Améliorations Proposées

1. **Filtrage HTTPS** : Ajouter une règle pour le port 443 afin de sécuriser les flux chiffrés.
2. **Zone DMZ** : Créer une troisième zone isolée pour les serveurs publics afin de protéger davantage le LAN.